WAS Experiment 10

Aim: Generating Penetration Test Report with CVSS

Learning Objective: To demonstrate the process of documenting penetration testing findings and assigning appropriate Common Vulnerability Scoring System (CVSS) severity scores to vulnerabilities identified during an authorized security assessment.

Learning Objectives:
After completing this experiment, students will be able to:

- Understand the purpose of a penetration testing report.
- Understand the importance of vulnerability documentation.
- Explain the CVSS scoring system.
- Identify vulnerability severity levels.
- Calculate or determine an appropriate CVSS score.
- Document vulnerability details in a structured format.
- Provide evidence and remediation recommendations.
- Prepare a professional penetration testing report.

Tools: Kali Linux, Burp Suite, Nmap, OWASP ZAP / other authorized security-testing tools, CVSS Calculator, Text editor or Microsoft Word and Authorized test environment.

Theory:

Introduction

A penetration test report is a formal document that records the vulnerabilities identified during a security assessment.
A good penetration testing report should clearly communicate:

- What vulnerability was identified.
- Where the vulnerability exists.
- How it was identified.
- What impact it can have.
- How severe the vulnerability is.
- Evidence supporting the finding.
- How the vulnerability can be remediated.

The report allows technical teams and management to understand the security risks identified during testing and prioritize remediation.

What is CVSS?

Common Vulnerability Scoring System (CVSS) is a standardized framework used to communicate the severity of security vulnerabilities.
CVSS produces a numerical score that helps organizations prioritize vulnerabilities.

CVSS Metrics

CVSS evaluates several characteristics of a vulnerability.
Important Base Metrics include:

- Attack Vector (AV) — How the vulnerability can be exploited.

- Attack Complexity (AC) — How difficult exploitation is.
- Privileges Required (PR) — Whether authentication or privileges are required.
- User Interaction (UI) — Whether another user's interaction is required.
- Scope (S) — Whether exploitation affects resources beyond the vulnerable security authority.
- Confidentiality (C) — Impact on confidentiality.
- Integrity (I) — Impact on integrity.
- Availability (A) — Impact on availability.

The selected metrics are used to determine the CVSS Base Score.

Vulnerability Severity

A penetration testing report commonly categorizes findings according to their severity.

1. Critical - A vulnerability with extremely high impact and/or exploitability that requires immediate attention.
2. High - A serious vulnerability that could significantly compromise an application, system, or sensitive information.
3. Medium - A vulnerability with a meaningful security impact but generally requiring additional conditions or having more limited consequences.
4. Low - A vulnerability with limited security impact.
5. Informational - An observation that does not represent a direct vulnerability but may be useful for improving security.

Penetration Testing Report Structure

A penetration testing report generally contains:

1. Executive Summary
2. Scope
3. Methodology
4. Findings
5. Risk Rating
6. Evidence
7. Impact
8. Remediation
9. Conclusion

Sample Penetration Test Finding

Finding 1: Reflected Cross-Site Scripting
Vulnerability: Reflected XSS
Severity: High
CVSS Score: Determined using the appropriate CVSS version and metrics
Affected Component: Web application's search parameter
Description - The application reflects user-controlled input into the HTTP response without applying appropriate output encoding.
Evidence - A controlled test input was submitted through the affected parameter, and the application reflected the input in the response.
Impact - Successful exploitation could allow attacker-controlled JavaScript to execute in a victim's browser within the security context of the vulnerable application.
Recommendation - Implement context-aware output encoding and validate untrusted input. A suitable

Content Security Policy can provide an additional layer of protection.

Procedure:

Step 1: Define the Scope

Identify the systems, applications, IP addresses, and domains that are authorized for testing.

Example:

Target: Authorized Web Application

Testing Environment: Laboratory

Testing Period: Practical Session

Expected Output:

The authorized testing scope is clearly defined.

Step 2: Perform Security Testing

Use authorized security-testing tools such as Burp Suite, Nmap, or OWASP ZAP to identify vulnerabilities.

For example, testing may identify:

- SQL Injection
- Cross-Site Scripting
- Missing security headers
- Authentication weaknesses
- Insecure configurations

Expected Output:

Potential security findings are identified.

Step 3: Record Each Finding

For every vulnerability, record:

- Finding name
- Affected URL/system
- Vulnerability type
- Description

- Severity
- CVSS score
- Evidence
- Impact
- Remediation

Expected Output:

Each vulnerability is documented in a structured format.

Step 4: Determine the CVSS Metrics

For each vulnerability, determine the appropriate CVSS metrics based on the characteristics observed during testing.

For example, consider:

Attack Vector

Attack Complexity

Privileges Required

User Interaction

Scope

Confidentiality

Integrity

Availability

Expected Output:

A CVSS metric vector is established for the vulnerability.

Step 5: Calculate the CVSS Score

Enter the selected metrics into an appropriate CVSS calculator.

The calculator generates:

- CVSS Base Score
- Severity Rating
- CVSS Vector

Expected Output:

A numerical CVSS score and severity rating are obtained.

Step 6: Document Evidence

Include evidence demonstrating the vulnerability.

Evidence may include:

- Screenshots
- HTTP requests
- HTTP responses
- Nmap output
- Burp Suite findings
- Relevant application output

For example:

Finding: Reflected XSS

Affected Parameter: search

Evidence: Application reflected unsanitized input

CVSS: [Calculated Score]

Severity: [Calculated Severity]

Expected Output:

The finding contains sufficient evidence to support the reported vulnerability.

Step 7: Describe the Impact

Explain what could happen if the vulnerability were successfully exploited.

For example:

Impact:

An attacker may be able to execute unauthorized

client-side code in the context of the vulnerable

web application.

The impact should be specific to the vulnerability and affected system.

Expected Output:

The security consequences of the vulnerability are clearly documented.

Step 8: Provide Remediation

Provide practical recommendations for fixing the vulnerability.

For example, for SQL Injection:

Use parameterized queries or prepared statements

and perform appropriate server-side input validation.

For XSS:

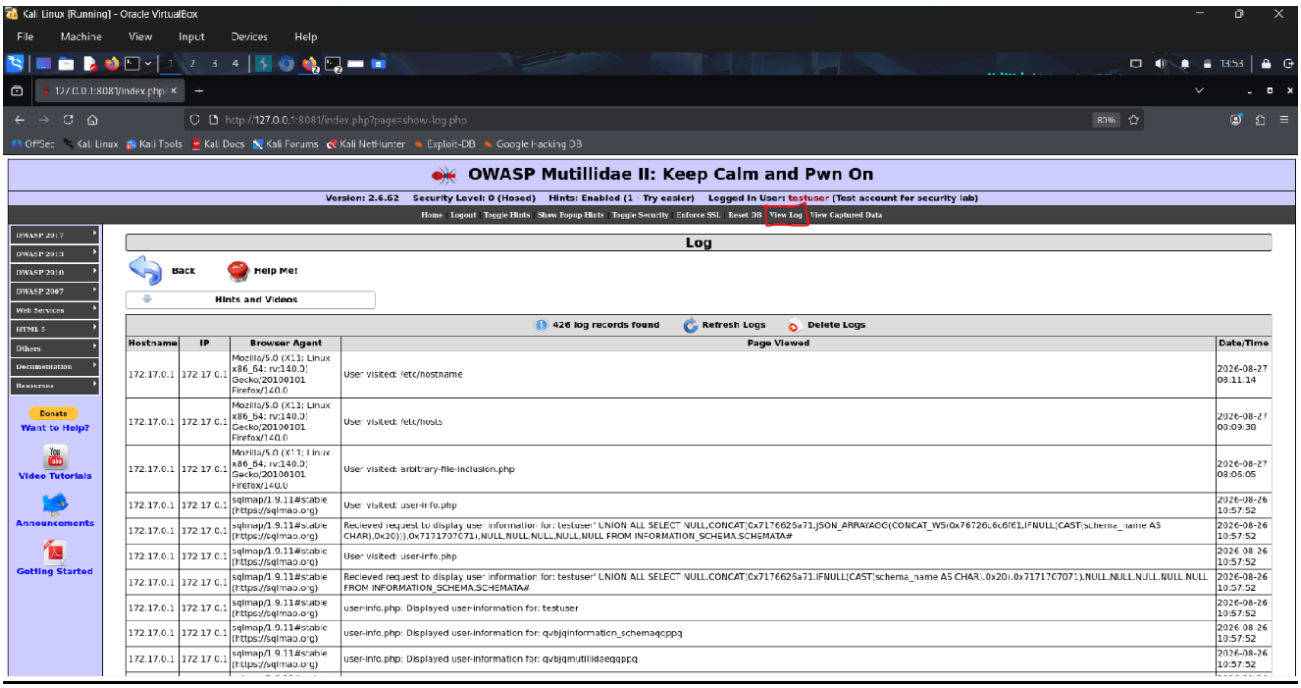
Apply context-aware output encoding and safely

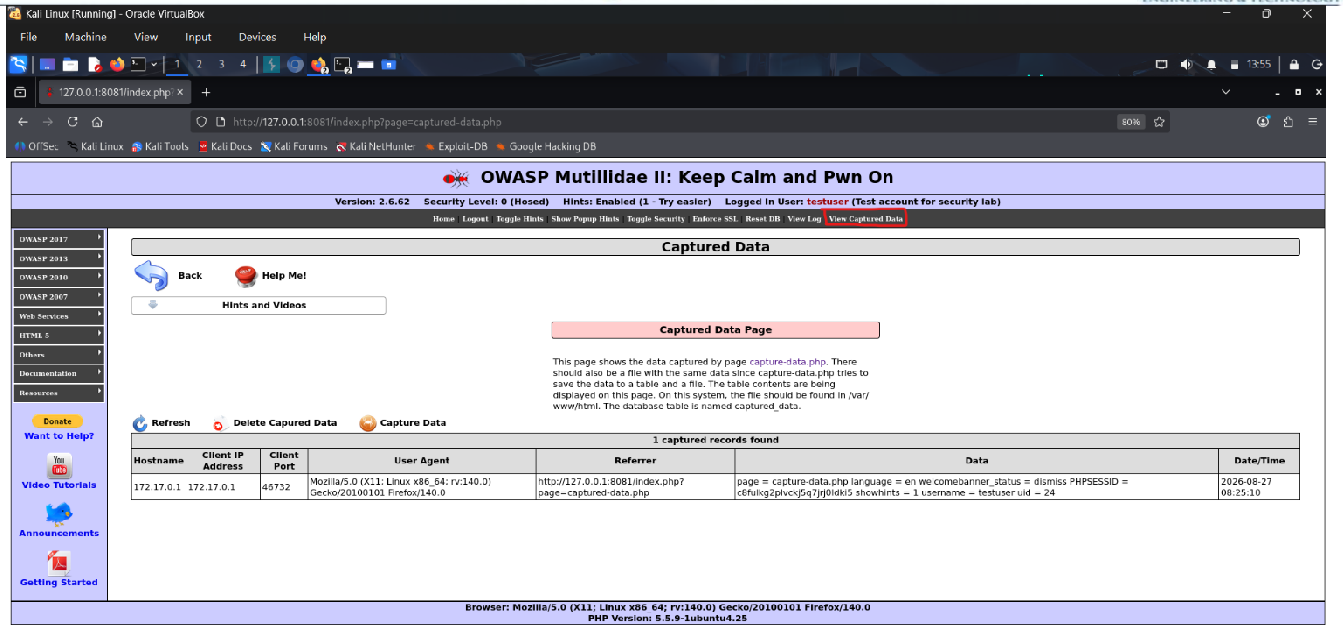
handle untrusted input.

Expected Output:

The report provides actionable remediation guidance.

Outputs:






```
┌──(kali㉿kali)-[~]
└─$ ls -lah ~/.local/share/sqlmap/output/
total 12K
drwxrwxr-x 3 kali kali 4.0K Aug 26 16:27 .
drwxrwxr-x 4 kali kali 4.0K Aug 26 16:24 ..
drwxrwxr-x 2 kali kali 4.0K Aug 26 16:27 127.0.0.1

┌──(kali㉿kali)-[~]
└─$ cd ~/.local/share/sqlmap/output/127.0.0.1

┌──(kali㉿kali)-[~/…/share/sqlmap/output/127.0.0.1]
└─$ ls -lah
total 32K
drwxrwxr-x 2 kali kali 4.0K Aug 26 16:27 .
drwxrwxr-x 3 kali kali 4.0K Aug 26 16:27 ..
-rw-rw-r-- 1 kali kali 1.6K Aug 26 16:27 log
-rw-r--r-- 1 kali kali  16K Aug 26 16:27 session.sqlite
-rw-rw-r-- 1 kali kali  342 Aug 26 16:27 target.txt

┌──(kali㉿kali)-[~/…/share/sqlmap/output/127.0.0.1]
└─$ nano ~/pentest_report.csv

┌──(kali㉿kali)-[~/…/share/sqlmap/output/127.0.0.1]
└─$ cat ~/pentest_report.csv
Experiment,Vulnerability,Target,Tool,Finding,Status
5,Session and Authentication,Mutillidae,OWASP Mutillidae,Session testing performed,Completed
6,XSS,Mutillidae,Burp Suite,Reflected Stored and DOM XSS tested,Completed
7,CSRF,Mutillidae,Burp Suite,CSRF attack simulated,Completed
8,SQL Injection,127.0.0.1,SQLMap,MySQL detected and databases enumerated,Completed
9,File Inclusion,127.0.0.1,Firefox,Local file contents accessed,Completed
10,Penetration Test Report,127.0.0.1,CSV,Findings documented,Completed
```

Observation:

The following observations are made:

1. Penetration testing findings need to be documented systematically.
2. Each finding should contain sufficient technical evidence.
3. CVSS provides a standardized method for communicating vulnerability severity.
4. CVSS metrics are selected according to the characteristics and impact of the vulnerability.
5. A numerical CVSS score helps prioritize remediation.
6. Remediation recommendations should directly address the identified vulnerability.

Result and Discussion:

The experiment successfully demonstrated the process of generating a penetration testing report using CVSS.

Security findings were documented with their descriptions, affected components, evidence, impact, severity, and remediation recommendations. CVSS metrics were used to determine the severity of a vulnerability and communicate its risk in a standardized manner.

The experiment demonstrated that a penetration testing report should provide both technical details for security teams and clear risk information for decision-makers.

Conclusion:

This experiment demonstrated how to document security vulnerabilities in a structured penetration testing report and assign an appropriate CVSS severity rating.

A well-prepared report provides evidence, explains the potential impact of each vulnerability, assigns a standardized severity score, and provides practical remediation recommendations. CVSS helps organizations prioritize vulnerabilities according to their security risk.

Viva Questions:

1. What is a penetration testing report?
2. What is CVSS?
3. What is the CVSS score range?

For Faculty Use:

Correction Parameters	**Formative Assessment [40%]**	**Timely completion of Practical [40%]**	**Attendance / Learning Attitude [20%]**	
Marks Obtained				